

Footprinting & Reconnaissance

Passive & Active Information Gathering Techniques

Study Notes — Lab Walkthrough on Target: **certifiedhacker.com**
(EC-Council's official practice/training domain used for ethical hacking labs)

■■ These techniques are demonstrated only on a domain that EC-Council provides specifically for legal, hands-on CEH training. Never run scanning/footprinting tools against a system you do not own or have written authorization to test.

What is Footprinting?

Footprinting (also called reconnaissance) is the **first phase** of ethical hacking / penetration testing. The goal is to collect as much information as possible about a target organization — domain details, IP addresses, network paths, DNS records, hosting provider, employees, and technologies in use — **without directly attacking the system**. This information helps an attacker (or a pentester) plan the next phases: scanning, enumeration, and exploitation.

Types of Footprinting

- **Passive Footprinting** — Gathering information without directly interacting with the target (e.g. WHOIS, search engines, social media, public databases). Very hard to detect.
- **Active Footprinting** — Directly interacting with the target's systems (e.g. traceroute, DNS queries, ping). Can potentially be logged/detected by the target.

■ **Key takeaway:** Footprinting builds a complete profile of the target before any real attack — the more information gathered here, the more precise later attack phases become.

1. SSL Certificate Analysis — Netcraft Site Report

Tool: Netcraft (Site Report / SSL/TLS Certificate lookup)

Type: Passive Footprinting

Netcraft's site report reveals detailed information pulled from a website's SSL/TLS certificate, without ever touching the target server directly for attack purposes.

What was found for **mail.certifiedhacker.com**:

- **Common Name:** mail.certifiedhacker.com
- **Assurance:** Domain Validation (DV) — only proves domain ownership, not company identity
- **Organisation / State / Country:** Not Present (typical of free DV certificates)
- **Subject Alternative Names (SAN):** autodiscover, cpanel, mail, webdisk, webmail, www.certifiedhacker.com — this reveals **other subdomains** hosted under the same certificate!
- **Issuing Organisation:** Let's Encrypt (free, automated CA)
- **Validity Period:** ~90 days (typical of Let's Encrypt certificates)
- **Perfect Forward Secrecy:** Yes — session keys can't be recovered even if the private key is later compromised
- **ALPN Protocol:** h2 (HTTP/2 supported)

■ **Key takeaway:** The SAN field in an SSL certificate is a goldmine for subdomain enumeration — it can expose hidden panels like cpanel, webmail, autodiscover that are not linked publicly.

2. Domain / IP Intelligence Dashboard (Domain Profiler tool)

Tool: Domain/IP Profiler dashboard (e.g. Netcraft / similar OSINT tool)

Type: Passive Footprinting

A visual dashboard correlates every discovered subdomain (A record) with its IP address, hosting ASN (Autonomous System Number), and banner grabbing results — all from a pre-built dataset, without sending live packets to the target.

Key data observed:

- **A Records (subdomains):** autodiscover.certifiedhacker.com, box5331.bluehost.com — both resolve to 162.241.216.11
- **ASN 31898** — ORACLE-BMC-31898 (Oracle Corporation, hosting most of the target's services)
- **ASN 13335** — CLOUDFLARENET (Cloudflare, Inc.) — some traffic is proxied through Cloudflare's CDN/WAF
- **Banners captured:** Apache (web server), Pure-FTPd (FTP server banner leaking user count and local time!), SSH-2.0-OpenSSH_8.7

Domain Profiler Summary Report — Top 5 tables:

Top 5 Banners	Count
Apache	76
20-Welcome to Pure-FTPd	38
SSH-2.0-OpenSSH_8.7	38
cloudflare	7

The banner grab shows FTP and SSH services exposed, alongside Apache web servers — mostly hosted on Oracle's ASN with a small fraction behind Cloudflare.

■ **Key takeaway:** Banner grabbing reveals exact service versions (e.g. OpenSSH_8.7) which can then be matched against known CVEs during the vulnerability-assessment phase.

3. Username / People Search — Sherlock (OSINT tool)

Tool: Sherlock (Python OSINT username hunter)

Type: Passive Footprinting (People Search / Social Engineering recon)

Sherlock searches for a given username across hundreds of websites and social platforms to see where an account with that name exists. It's commonly used to build a profile of an individual (useful before social-engineering / spear-phishing attacks).

```
root@parrot:~# sherlock "Elon Musk"
[*] Checking username Elon Musk on:
[+] Airlines: https://www.airliners.net/user/Elon%20Musk/profile/photos
[+] Apple Developer: https://developer.apple.com/forums/profile/Elon%20Musk
[+] Codeforces: https://codeforces.com/profile/Elon%20Musk
[+] GeeksforGeeks: https://auth.geeksforgeeks.org/user/Elon%20Musk
... (matches across 100s of sites)
```

- Sherlock queries each site's profile URL pattern and checks the HTTP response to confirm the account exists
- Useful for mapping a person's **digital footprint** — which forums, dev platforms, or social sites they use
- Run with: `sherlock <username>`

■ **Key takeaway:** People-search tools like Sherlock are used in the 'human OSINT' side of footprinting — identifying employees and their online presence to craft targeted phishing or pretexting attacks.

4. WHOIS Lookup — DomainTools

Tool: DomainTools WHOIS Lookup

Type: Passive Footprinting

WHOIS queries the domain registrar's database to reveal registration and ownership details for a domain name.

WHOIS record for **certifiedhacker.com**:

- **Registrar:** Network Solutions, LLC
- **Registrar Status:** clientTransferProhibited (prevents unauthorized domain transfer)
- **Created:** 2002-07-30 | **Expires:** 2027-07-30 | **Updated:** 2026-05-30 (domain is 8,734 days old)
- **Name Servers:** NS1.BLUEHOST.COM, NS2.BLUEHOST.COM — confirms the domain is hosted with Bluehost
- **IP Address:** 162.241.216.11 (752 other sites share this same server — shared hosting)
- **IP Location:** Utah, Provo — Unified Layer (Bluehost's parent company)
- **ASN:** AS31898 ORACLE-BMC-31898 - Oracle Corporation

■ **Key takeaway:** WHOIS instantly tells you the registrar, hosting provider, domain age, and name servers — often the very first command run in any footprinting engagement.

5. DNS Enumeration — nslookup (Windows CMD)

Tool: nslookup (built-in Windows/Linux DNS query utility)

Type: Active Footprinting (queries a DNS server, but not the target directly)

nslookup lets you query specific DNS record types (A, CNAME, MX, NS, etc.) for a domain.

```
C:\Users\Admin> nslookup
Default Server: dns.google
Address: 8.8.8.8

> set type=a
> www.certifiedhacker.com
Non-authoritative answer:
Name: certifiedhacker.com
Address: 162.241.216.11
Aliases: www.certifiedhacker.com

> set type=cname
> certifiedhacker.com
certifiedhacker.com
primary name server = ns1.bluehost.com
responsible mail addr = dnsadmin.box5331.bluehost.com
serial = 2025100600
refresh = 86400 (1 day)
retry = 7200 (2 hours)
expire = 3600000 (41 days 16 hours)
default TTL = 300 (5 mins)
```

- **set type=a** → resolves the A record → returns the IPv4 address (162.241.216.11)
- **set type=cname** (on a domain, actually returns the SOA record here) → reveals the **primary name server** and the **DNS admin's e-mail** (dnsadmin@box5331.bluehost.com)
- SOA fields (serial, refresh, retry, expire, TTL) show how often secondary DNS servers sync data

Online alternative — Web-based nslookup tool

The same lookup can be done from a browser using an online DNS tool (no need to install anything).

Query type A for **www.certifiedhacker.com** confirms the canonical name resolves to certifiedhacker.com → **162.241.216.11**.

■ **Key takeaway:** DNS interrogation reveals the authoritative name server, admin contact e-mail, and IP address — critical for mapping the target's network infrastructure.

6. Network Path Discovery — Traceroute / Tracert

Tools: tracert (Windows) | traceroute (Linux)

Type: Active Footprinting

Traceroute maps every router ("hop") a packet passes through on its way to the target, by sending packets with increasing TTL (Time To Live) values and recording which router replies at each TTL.

Windows — tracert

```
C:\Users\Admin> tracert -h 5 www.certifiedhacker.com
Tracing route to certifiedhacker.com [162.241.216.11]
over a maximum of 5 hops:

 1 <1 ms 103.177.47.1
 2 <1 ms 192.168.0.21
 3 1 ms 103.18.87.33
 4 * Request timed out.
 5 2 ms be5377.rcr71.b057205-0.sin01.atlas.cogentco.com [154.24.2.33]

Trace complete.
```

The `-h 5` flag limits the trace to 5 hops. Hop 4 timing out means that router is configured to drop/ignore ICMP TTL-exceeded probes (common security hardening).

Linux — traceroute (full path, 30 hops max)

```
# traceroute www.certifiedhacker.com
traceroute to www.certifiedhacker.com (162.241.216.11), 30 hops max
 1 10.10.1.2 1.574 ms
 2 172.18.0.1 1.309 ms
 3 192.168.0.29 1.061 ms
 4 103.18.87.33 1.773 ms
 5 * * *
 6 be5377.rcr71.b057205-0.sin01.atlas.cogentco.com (154.24.2.33)
 7 be9048.ccr81.sin01.atlas.cogentco.com (154.54.95.162)
 8 gtt.sin01.atlas.cogentco.com (154.54.140.46)
 9 ae17.cr8-phx1.ip4.gtt.net (141.136.110.250)
10 ip4.gtt.net (209.120.142.162)
11 140.204.226.71 / .83 / .125 (140.204.226.x)
12 * * *
13 box5331.bluehost.com (162.241.216.11)
```

- The path travels through **Cogent Communications** (cogentco.com) and **GTT** backbone networks before reaching **Bluehost's** server (box5331.bluehost.com)
- Hops showing * * * mean that router did not respond (ICMP filtered or rate-limited)
- The final hostname confirms the destination server name matches the WHOIS/DNS results above

■ **Key takeaway:** Traceroute confirms the real network path and ISPs/backbones a target's traffic travels through — useful for network diagramming and identifying possible intermediate targets.

7. AI-Assisted Reconnaissance — ShellGPT (sgpt)

Tool: sgpt (ShellGPT) --chat --shell

Type: Active Footprinting (AI-generated command execution)

ShellGPT lets a pentester describe a task in plain English, and it generates (and can execute) the matching shell command — speeding up recon without memorizing every tool's syntax.

```
root@parrot:~# sgpt --chat footprint --shell "Perform network traceroute to discover the routers on the path to a target host www.certifiedhacker.com"
```

```
traceroute www.certifiedhacker.com
[E]xecute, [D]escribe, [A]bort: E
```

```
traceroute to www.certifiedhacker.com (162.241.216.11), 30 hops max
 1 10.10.1.2 0.687 ms
 2 172.18.0.1 1.521 ms
 3 192.168.0.29 1.346 ms
 4 103.18.87.33 2.321 ms
 5 * * *
 6 be5377.rcr71.b057205-0.sin01.atlas.cogentco.com 3.136 ms
 ...
13 box5331.bluehost.com (162.241.216.11) 193.531 ms *
```

- The person types a natural-language request; ShellGPT converts it into the correct traceroute syntax
- It prompts **[E]xecute / [D]escribe / [A]bort** before running anything — a safety confirmation step
- Results match the manual traceroute output from Section 6 — confirming AI tools can automate recon steps

■ **Key takeaway:** AI shell assistants don't replace understanding the underlying commands — they simply save time recalling exact tool syntax during recon.

8. Automated OSINT Framework — Recon-ng

Tool: Recon-ng (modular web reconnaissance framework)

Type: Passive Footprinting

Recon-ng is a Metasploit-style framework purpose-built for web/OSINT recon. Modules are loaded inside a workspace and their results are stored in a local database that can be reported later.

8.1 — reverse_resolve module

```
[recon-ng][CEH][brute_hosts] > modules load recon/hosts-hosts/reverse_resolve
[recon-ng][CEH][reverse_resolve] > run
[*] Host: box5331.bluehost.com
[*] Ip_Address: 162.241.216.11
[*] 127.0.0.1 => No record found.
SUMMARY
[*] 1 total (1 new) hosts found.
```

This module takes an IP address and performs a **reverse DNS lookup** to find the hostname associated with it — here confirming 162.241.216.11 maps to box5331.bluehost.com.

8.2 — brute_hosts module results (subdomain brute-forcing)

The brute_hosts module tries common subdomain prefixes (mail, ftp, blog, news, imap, pop, smtp, webmail, events, demo...) against the base domain and records every one that resolves:

Host	IP Address	Module
autodiscover.certifiedhacker.com	162.241.216.11	brute_hosts
blog.certifiedhacker.com	162.241.216.11	brute_hosts
box5331.bluehost.com	162.241.216.11	reverse_resolve
demo.certifiedhacker.com	162.241.216.11	brute_hosts
ftp.certifiedhacker.com	162.241.216.11	brute_hosts
localhost.certifiedhacker.com	127.0.0.1	brute_hosts
mail.certifiedhacker.com	—	brute_hosts
news.certifiedhacker.com	162.241.216.11	brute_hosts
smtp / pop / imap.certifiedhacker.com	162.241.216.11	brute_hosts
webmail.certifiedhacker.com	162.241.216.11	brute_hosts
www.certifiedhacker.com	162.241.216.11	brute_hosts

Almost every subdomain resolves to the **same shared-hosting IP** (162.241.216.11), confirming all services (mail, ftp, blog, webmail...) live on one Bluehost server.

8.3 — whois_pocs module (WHOIS Points of Contact)

This module extracts human contacts (POCs) registered against a domain in the ARIN WHOIS database — demonstrated here on facebook.com as an example of the module's output format:

```
[recon-ng][reconnaissance][whois_pocs] > run
-----
FACEBOOK.COM
-----
[*] URL: http://whois.arin.net/rest/poc/BST184-ARIN
[*] Country: United States
[*] Email: bstout@facebook.com
[*] First_Name: Brandon
[*] Last_Name: Stout
[*] Region: Chicago, IL
[*] Title: Whois contact
-----
[*] URL: http://whois.arin.net/rest/poc/OPERA82-ARIN
```

```
[*] Email: domain@facebook.com
[*] Last_Name: Operations
```

This can reveal **real employee names, e-mails, and job titles** tied to a domain's registration — valuable for social-engineering attack planning.

8.4 — Full hosts report summary

After running all recon modules, Recon-ng's reporting engine compiles every discovered host into one exportable report:

```
[*] Host: www.website-215f0f34.certifiedhacker.com Ip_Address: 162.241.216.11
[*] Host: www.certifiedhacker.com Ip_Address: 162.241.216.11
-----
SUMMARY
-----
[*] 38 total (38 new) hosts found.
```

■ **Key takeaway:** Recon-ng automates and stores the entire footprinting workflow (DNS brute-force, reverse lookups, WHOIS contacts) into one searchable database — turning hours of manual work into a few commands.

Quick-Revision Summary Table

Tool / Technique	Passive / Active	Information Revealed
Netcraft SSL Report	Passive	SSL cert details, SAN subdomains, DV/OV/EV level
Domain Profiler / IP Dashboard	Passive	ASN, hosting provider, banners (Apache/FTP/SSH)
Sherlock	Passive	Social media / platform accounts of a username
WHOIS (DomainTools)	Passive	Registrar, name servers, domain age, IP location
nslookup	Active	A / CNAME / SOA / MX records, DNS admin e-mail
tracert / traceroute	Active	Network path, ISPs/backbones, routers (hops)
ShellGPT (sgpt)	Active	AI-generated recon commands (e.g. traceroute)
Recon-ng	Passive	Subdomain brute-force, reverse DNS, WHOIS POCs

Exam / Interview Tips

- Passive footprinting = no direct packets sent to the target (WHOIS, Netcraft, search engines, social media).
- Active footprinting = direct interaction with the target's systems (nslookup, traceroute, ping) — can be logged.
- SSL SAN fields and subdomain brute-forcing are two of the fastest ways to expand an attack surface map.
- Always correlate multiple sources (WHOIS + DNS + traceroute) — they should agree on the same IP/hosting provider.
- Remember: footprinting never exploits anything — it only gathers information for planning later phases.